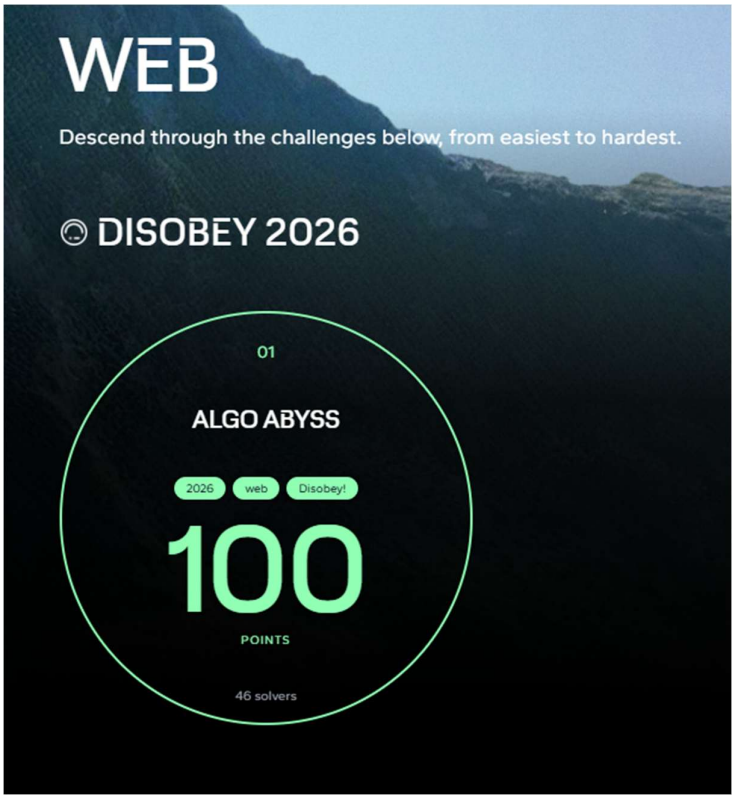
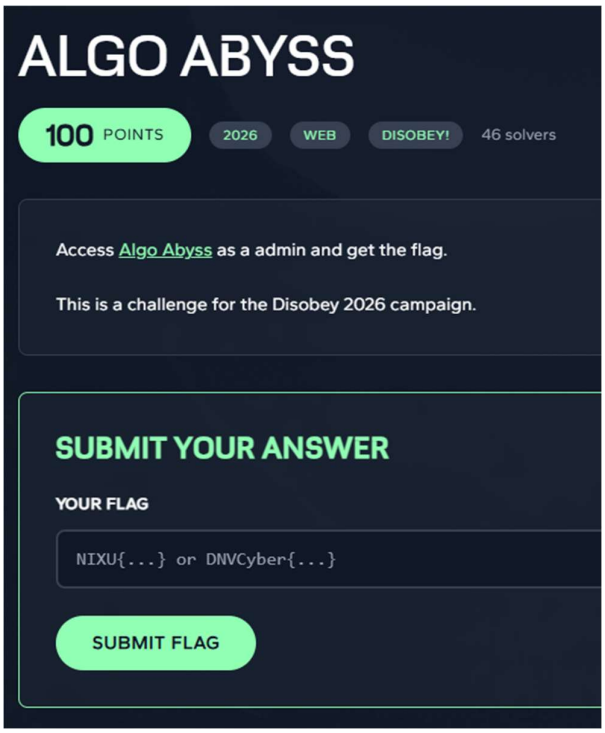
Algo Abyss



Kuvaus: Access Algo Abyss as a admin and get the flag (kuva 17).

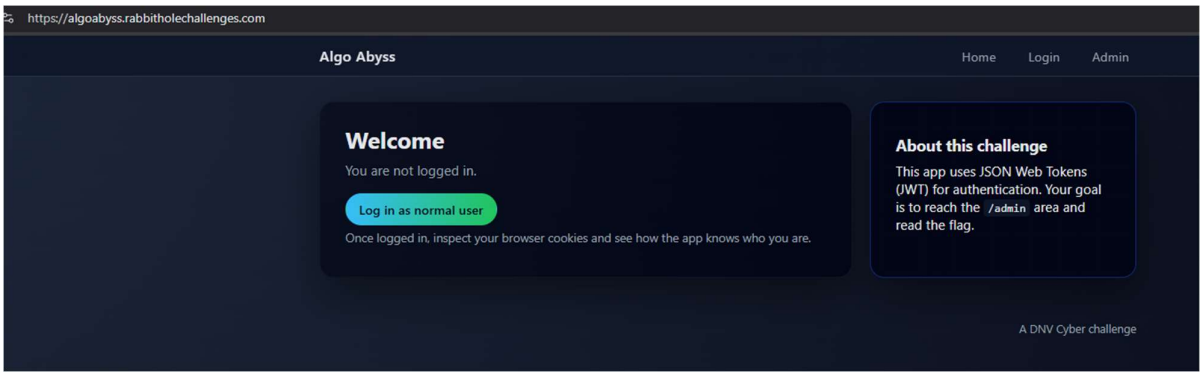


Kuva 17: Taustatiedot.

Tutkinta

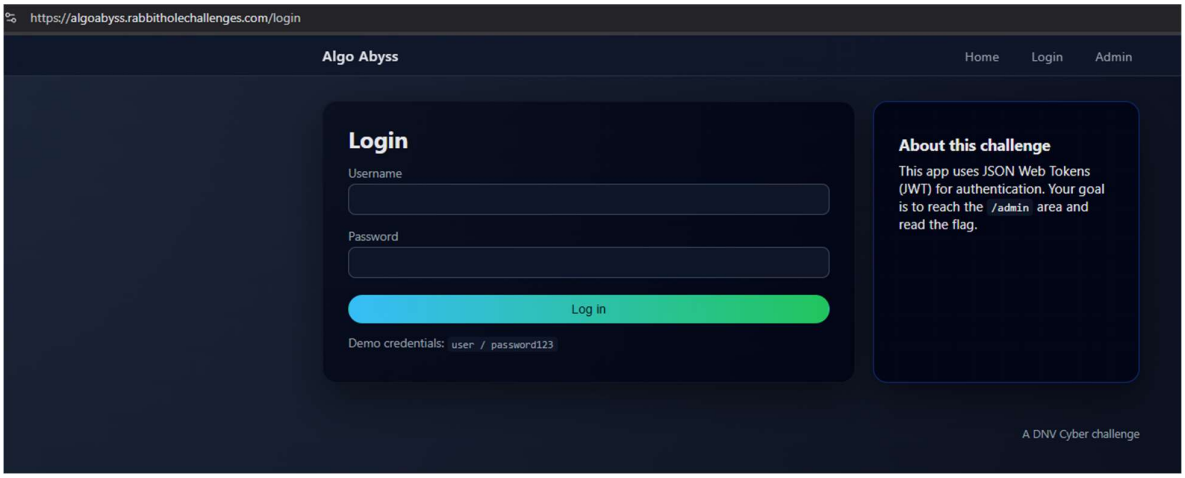
Kyseessä on web-haavoittuvuus web-sivustolla.

Näen, että kyseessä on admin oikeuksilla sivustolle sisään kirjautuminen. Tämä on tuttua useammista haasteista, joten avaan sivun (kuva 18):

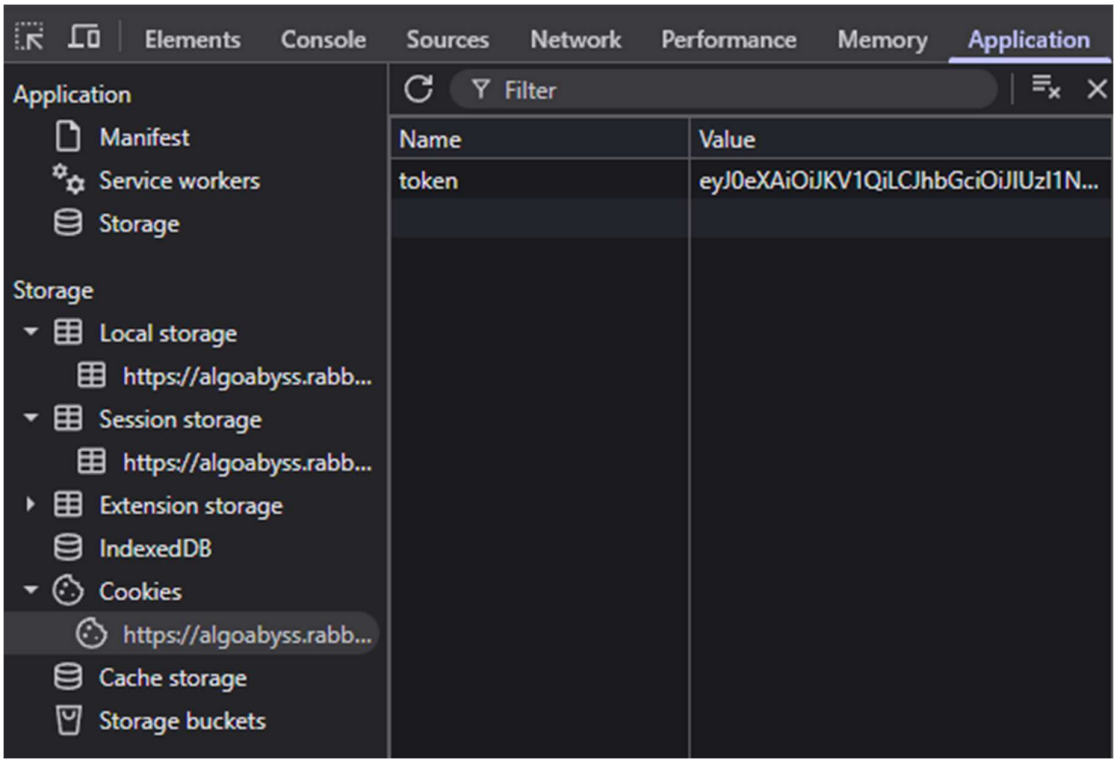


Kuva 18: Sivustonäkymä.

Siirryn admin -kirjautumissivulle:

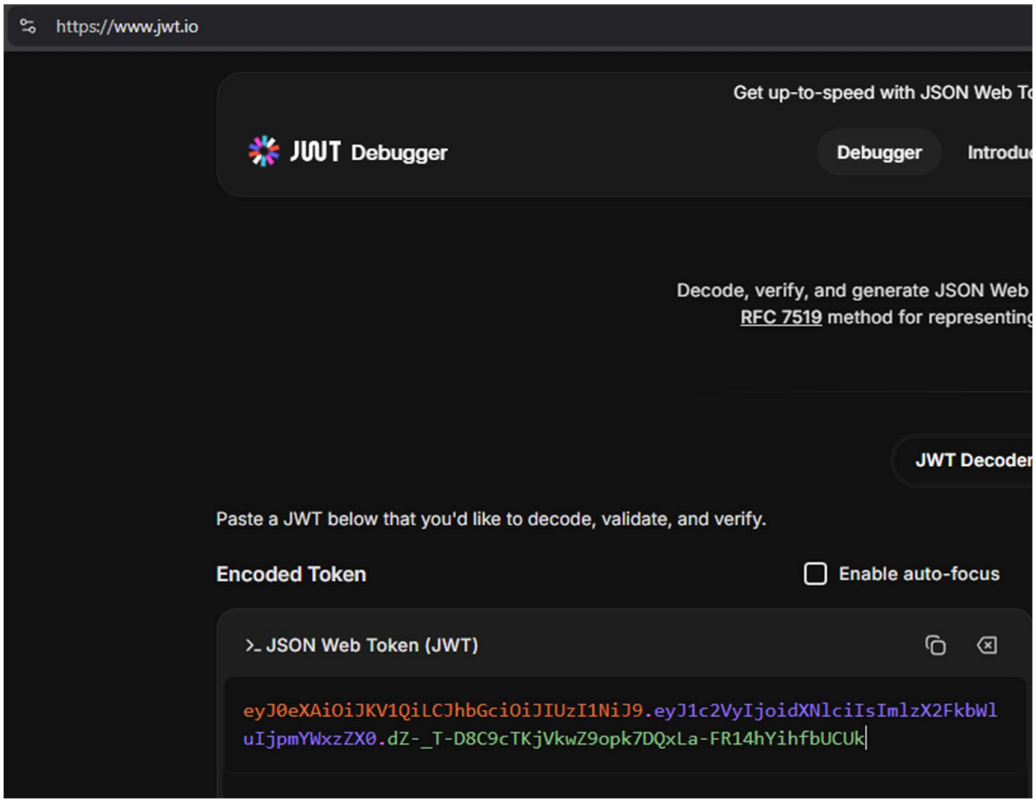


Vihjeessä oikealla lukee maininta JSON Web tokeneista. Avaan developer tilan näppäimellä F12, siirryn Application / Storage, naputtelen läpi local storage ja session storage yrittäen löytää tokenia. Cookies löytyy (kuva 19):



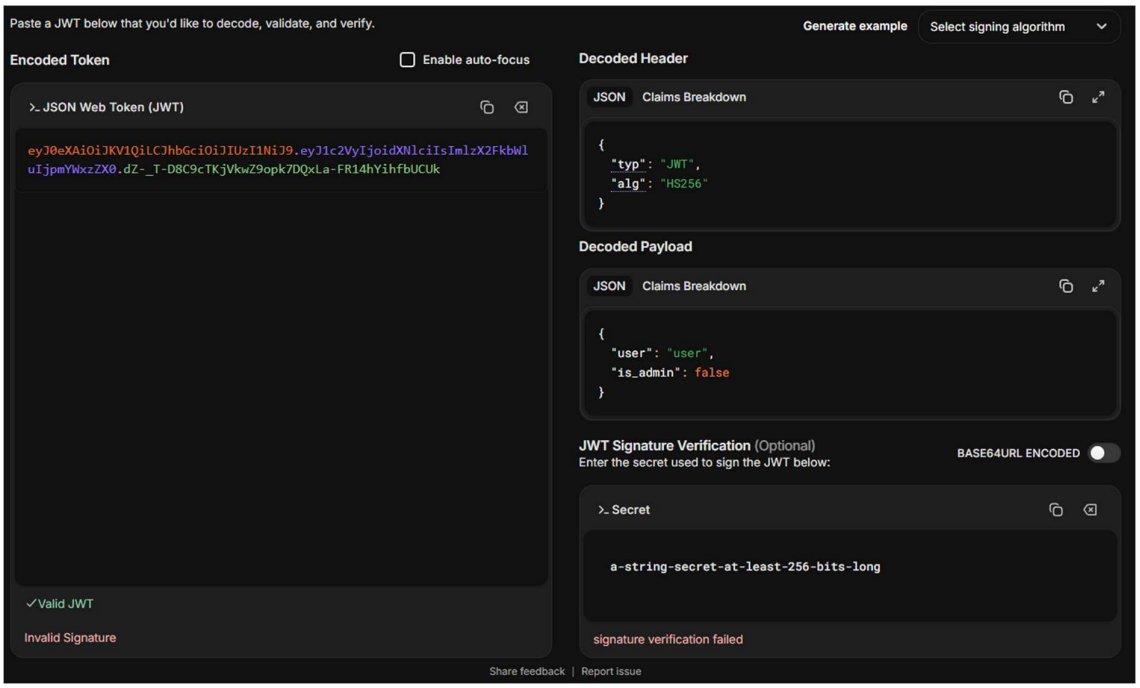
Kuva 19: Cookie token.

Menen osoitteeseen jwt.io, jossa voin tutkia tokenia (kuva 20):



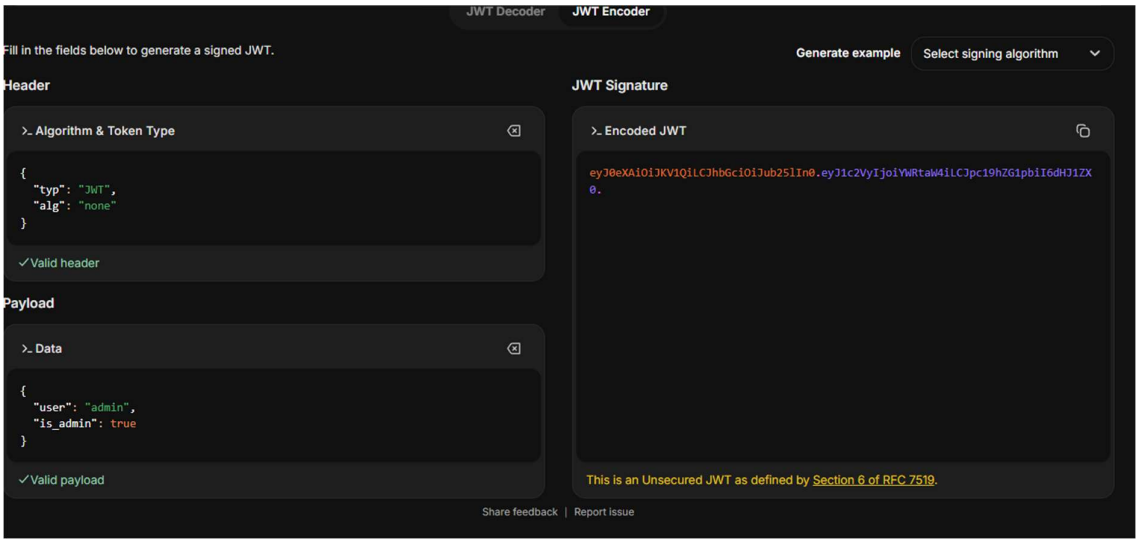
Kuva 20: Token liitetty vasemmalle.

Tässä näen, mitä tokeni sisältää, kiinnostavaa on erityisesti dataosa, joka näyttää että token on nimenomaan user, ei admin (kuva 21):

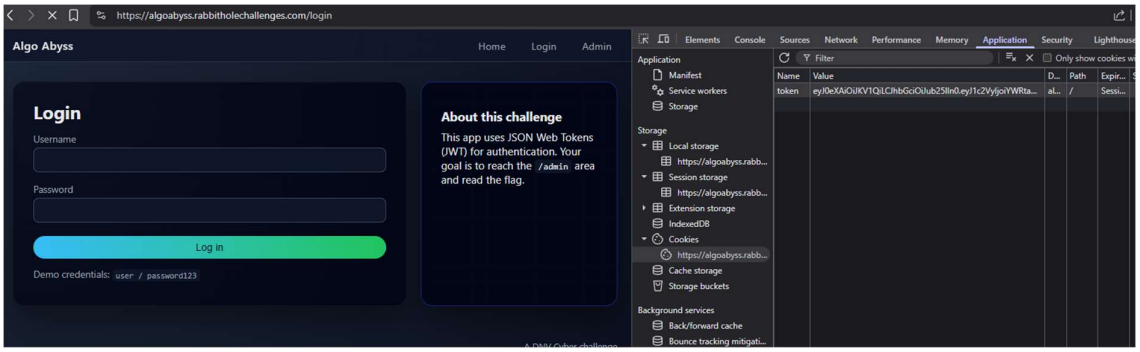


Kuva 21: Ennen header ja Payload muutoksia.

Muokkaan Headerin ja Payloadin (dataosa) seuraavasti:

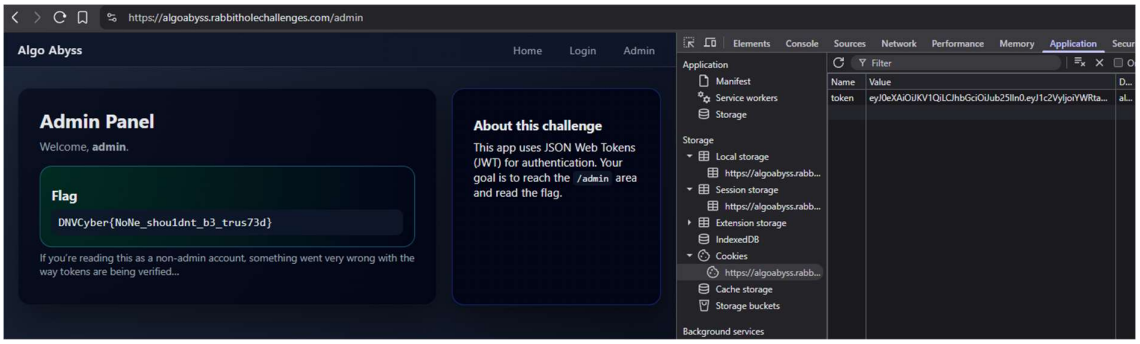


Kopioin uuden saamani tokenin ja koitan sitä Cookies-kohtaan sivustolla (kuva 22):

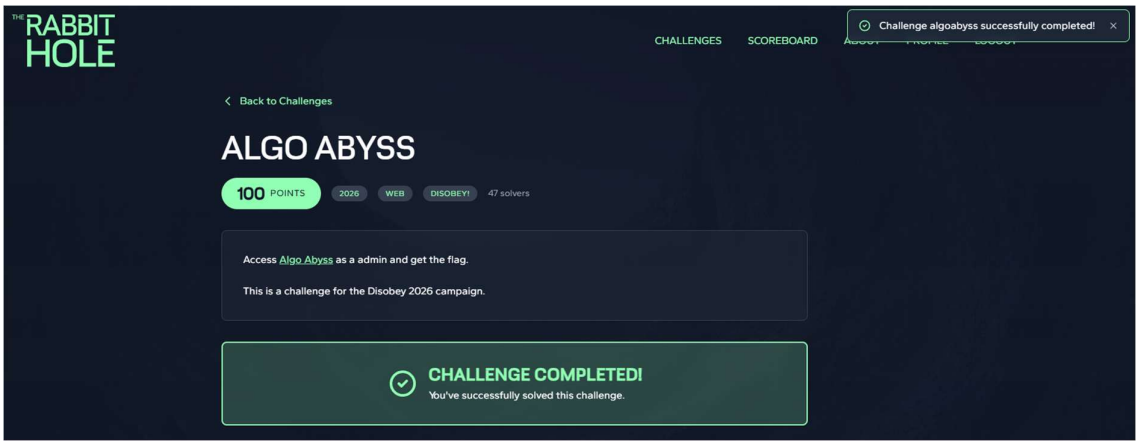


Kuva 22: Token vaihdettu.

Tokenin vaihdon jälkeen kirjoitin osoiterivin perään /admin (olisin myös voinut valita valikosta Admin), ja pääsin sisään (kuva 23):



Kuva 23: DNVCyber{NoNe_shou1dnt_b3_trus73d}



Kuva 24: Haaste suoritettu.